

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 07

Domain III - Information Security Program

50 Questions	80 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 80 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM2-058)

Scenario: Two regional transportation companies have merged. They use different operating models, and leaders want a unified security program without disrupting scheduled services.

What should provide the PRIMARY basis for the unified program's objectives?

- A. The larger company's existing technology inventory
- B. The security team's preferred future tools
- C. The controls that can be implemented with no process changes
- D. The merged business objectives, critical services, obligations, and risk priorities

Question 2 (CISM2-059)

Scenario: A family-owned manufacturer is formalizing security for the first time. Managers agree that improvement is needed but dispute who can set enterprise requirements and assign responsibilities.

What should the information security manager develop FIRST?

- A. A complete catalog of technical configurations
- B. A schedule of unannounced compliance inspections
- C. An executive-sponsored program charter defining authority, scope, objectives, and accountability
- D. A list of products to standardize across all facilities

Question 3 (CISM2-060)

Scenario: A digital bank advances the launch of an open partner interface by nine months. The current security roadmap schedules interface governance and service monitoring after the new launch date.

Which roadmap action should the information security manager take NEXT?

- A. Keep the approved sequence because roadmap dates should never change.
- B. Add more security projects without changing priorities or resources.
- C. Transfer launch approval to the monitoring team.
- D. Reassess risk, dependencies, capacity, and launch needs, then propose a revised roadmap.

Question 4 (CISM2-061)

Scenario: An energy company forms a joint venture that will use the parent companies' systems and share operational data. The agreement describes commercial duties but not security responsibilities.

Which approach would BEST establish the security program scope?

- A. Exclude the venture because neither parent owns all supporting systems.
- B. Apply only the less demanding parent's security requirements.
- C. Make the joint venture's technology provider accountable for all business risk.
- D. Map information flows, services, obligations, and risks, then assign responsibilities at every organizational boundary.

Question 5 (CISM2-062)

Which information is MOST useful when estimating resources for a new security capability?

- A. The maximum headcount requested by another department
- B. The current security department's reporting hierarchy
- C. Required outcomes, workload, service levels, competencies, dependencies, and sourcing options
- D. The number of security technologies advertised during the year

Question 6 (CISM2-063)

Scenario: A credit union plans to outsource vulnerability scanning and initial analysis. Internal service owners still control remediation schedules and understand business criticality.

Which operating model is MOST appropriate?

- A. Allow the provider to accept residual risk for overdue vulnerabilities.
- B. Define provider deliverables and quality measures while retaining internal prioritization, ownership, and oversight.
- C. Require the provider to approve changes to all business services.
- D. Stop internal monitoring because scanning has been outsourced.

Question 7 (CISM2-064)

Scenario: A legal services group cannot reliably locate confidential client data across collaboration platforms. Executives will consider funding a discovery and classification capability if its value is clearly demonstrated.

Which business case would be MOST persuasive?

- A. One based only on the number of features in the preferred product
- B. One promising that the investment will eliminate all information risk
- C. One linking expected risk reduction and operational benefits to lifecycle cost, dependencies, and measurable outcomes
- D. One based on the security manager's personal preference

Question 8 (CISM2-065)

Scenario: A fast-growing education provider relies on one employee for security architecture and cloud reviews. Project demand is increasing, and no other team member can perform the role.

Which action should the manager take FIRST to reduce this dependency?

- A. Stop documenting the role to protect specialist knowledge.
- B. Assign all reviews to project managers without training.
- C. Assess capacity risk and establish backup skills, knowledge transfer, and sourcing.
- D. Wait for the specialist to leave before requesting resources.

Question 9 (CISM2-066)

Which role is normally responsible for implementing storage and backup requirements defined by an information owner?

- A. Risk owner
- B. Information custodian
- C. Policy approver
- D. Internal auditor

Question 10 (CISM2-067)

What makes an information asset inventory MOST useful to a security program?

- A. It contains only assets purchased by the technology department.
- B. It is updated only during external audits.
- C. It assigns the same protection requirement to every record.
- D. It links assets to business use, accountable owners, classification, location, and lifecycle state.

Question 11 (CISM2-068)

Scenario: An architecture firm labels bid documents as restricted, but employees share them through any available collaboration space because approved handling methods are unclear.

Which program change would BEST correct the handling gap?

- A. Define and embed approved sharing, access, retention, and disposal requirements for the restricted classification.
- B. Remove the restricted label so current sharing behavior becomes compliant.
- C. Require the security manager to approve every document access request.
- D. Measure only how many documents receive a label.

Question 12 (CISM2-069)

Scenario: Analysts at a consumer goods company export sales data to personal workspaces for temporary modeling. Years of copies remain after projects close, with inconsistent access and no documented owners.

What should the information security manager recommend FIRST?

- A. Move every copy to permanent archive storage.
- B. Let each analyst decide whether old data has business value.
- C. Delete all copies immediately without checking retention requirements.
- D. Discover the copies, assign accountable ownership, and apply classification, retention, and defensible disposition rules.

Question 13 (CISM2-070)

What should an organization do before adopting a security framework as the basis for its program?

- A. Replace all existing governance structures with the framework.
- B. Assume adoption will make further risk decisions unnecessary.
- C. Require every framework practice regardless of relevance.
- D. Confirm that the framework fits organizational objectives, risks, obligations, and operating context.

Question 14 (CISM2-071)

Why is risk-based tailoring important when implementing a security framework?

- A. It guarantees that all residual risk will be eliminated.
- B. It allows teams to omit any difficult requirement without approval.
- C. It directs effort toward relevant outcomes while preserving traceability to applicable requirements.
- D. It makes management oversight unnecessary.

Question 15 (CISM2-072)

Scenario: A medical device company maintains separate control libraries for customer contracts, corporate policy, and two assurance frameworks. Control owners repeatedly provide equivalent evidence to different teams.

What is the MOST appropriate improvement?

- A. Map requirements to a shared control and evidence model with traceability.
- B. Discard all customer-specific requirements.
- C. Keep every library separate to demonstrate independence.
- D. Use only the framework with the shortest control descriptions.

Question 16 (CISM2-073)

Which document describes the step-by-step method for performing a security-related task?

- A. Policy
- B. Procedure
- C. Guideline
- D. Program charter

Question 17 (CISM2-074)

When is a security guideline MOST appropriate?

- A. When recommended approaches can help users meet requirements in varying circumstances
- B. When risk acceptance must be recorded
- C. When executive authority for the program must be established
- D. When a mandatory technical value must be enforced uniformly

Question 18 (CISM2-075)

Scenario: A factory cannot apply a newly approved endpoint standard to specialized production equipment until a scheduled maintenance shutdown. The plant manager requests an exception.

Which response is MOST appropriate?

- A. Allow the equipment operator to approve the exception informally.
- B. Remove production equipment from the standard permanently.
- C. Assess the risk, set compensating controls and review conditions, then obtain time-bound approval.
- D. Grant the exception until the equipment eventually reaches end of life.

Question 19 (CISM2-076)

Scenario: A customer-support procedure requires agents to retain identity evidence for five years, while the approved retention standard sets a two-year period for that evidence. Both documents name the same data category.

What should the manager do FIRST to resolve the inconsistency?

- A. Have owners determine requirements, then approve and communicate one consistent rule.
- B. Tell agents to choose the period they consider safer.
- C. Assume the longer period is automatically correct because it retains more evidence.
- D. Ignore the conflict until an auditor identifies a violation.

Question 20 (CISM2-077)

Scenario: A hospitality group lets each hotel select technology independently. The group is introducing shared loyalty services, but identity, logging, and data-protection approaches are incompatible.

What should the information security manager establish FIRST?

- A. A list of identical products that every hotel must purchase
- B. Security architecture principles and shared capability requirements aligned with the enterprise service model
- C. Detailed configuration commands for each local system
- D. A waiver allowing each hotel to preserve its current design indefinitely

Question 21 (CISM2-078)

Scenario: An enterprise architecture board approves new business platforms before the security architecture team learns about them. Security requirements are added later, creating redesign and inconsistent exceptions.

Which change would BEST address the root cause?

- A. Move all enterprise architecture decisions into the security department.
- B. Require internal audit to design each platform's controls.
- C. Review security only after procurement has signed each contract.
- D. Embed security architecture requirements and representation into enterprise architecture decision points.

Question 22 (CISM2-079)

Scenario: A national charity's target architecture includes centralized monitoring and identity services. The board cannot determine which strategic risks these investments are intended to reduce.

What should the security manager add to the architecture documentation?

- A. Traceability linking business objectives and risk scenarios to requirements, capabilities, and roadmap initiatives
- B. A statement that centralized services are always superior
- C. A list of the architecture team's professional qualifications
- D. A catalog of every configuration setting used by administrators

Question 23 (CISM2-080)

Scenario: A retailer's acquisition cannot immediately use the target identity architecture because of a legacy platform dependency. The acquisition team proposes a two-year local solution.

What is the MOST appropriate architecture decision?

- A. Reject every deviation regardless of operational impact.
- B. Remove the acquired company from architecture governance.
- C. Assess deviation risk, set interim safeguards, obtain approval, and track convergence.
- D. Let the solution vendor approve the residual risk.

Question 24 (CISM2-081)

Scenario: A securities exchange can modernize security logging through a rapid replacement or a phased transition. Rapid replacement shortens coexistence but creates a single high-impact cutover; phasing reduces cutover risk but requires temporary data reconciliation.

How should the information security manager recommend a path?

- A. Select the least expensive option without considering operational exposure.
- B. Compare risk reduction, resilience, dependencies, transition controls, and exit criteria.
- C. Choose rapid replacement because shorter schedules are always less risky.
- D. Let each system owner migrate independently without a shared roadmap.

Question 25 (CISM2-082)

Which metric BEST measures the outcome of a security exception-management capability?

- A. Active exceptions with authorized owners, safeguards, and timely review or closure.
- B. Hours spent configuring the workflow tool
- C. Number of fields contained in each request
- D. Number of employees who can access the exception form

Question 26 (CISM2-083)

Scenario: The percentage of timely supplier assessments has fallen, but the dashboard provides only one enterprise total. Leaders disagree about whether the cause is staffing, supplier volume, or delayed business input.

What information would MOST improve the decision?

- A. The number of colors available in the dashboard
- B. Trends by risk tier, process stage, owner, backlog age, and cause.
- C. The average length of completed questionnaires
- D. The total number of security policies published

Question 27 (CISM2-084)

Scenario: A mining company scores highly in several stable security capabilities but poorly in technology experimentation. A consultant recommends raising every capability to the same maturity level.

What should the information security manager recommend instead?

- A. Set maturity targets based on risk, business dependence, outcomes, and investment value.
- B. Invest only in capabilities with the lowest numerical score.
- C. Use peer maturity averages as mandatory targets.
- D. Stop maturity measurement because capabilities cannot be compared.

Question 28 (CISM2-085)

Why should a control objective be defined before a security control is selected?

- A. To assess whether the design addresses its intended risk and requirement.
- B. To make control ownership unnecessary
- C. To guarantee that the control will never fail
- D. To ensure the newest technology is always selected

Question 29 (CISM2-086)

Scenario: A laboratory cannot install standard endpoint software on certified instruments without invalidating support. The instruments process sensitive research and connect to a controlled network segment.

What should the security manager do?

- A. Install the software immediately despite the support impact.
- B. Exclude the instruments from security oversight.
- C. Assess threats and requirements, then design proportionate controls within operating constraints.
- D. Accept the risk because the standard control is unavailable.

Question 30 (CISM2-087)

Scenario: A software company plans to block unauthorized cloud services using a technical gateway. Its asset and service inventory is incomplete, and approved business services have no accountable owners.

What should concern the information security manager MOST?

- A. The control is preventive rather than exclusively detective.
- B. The gateway has fewer dashboard widgets than competing products.
- C. The security team did not select the most expensive option.
- D. The control lacks context to distinguish approved use and assign decisions.

Question 31 (CISM2-088)

Scenario: A design company is comparing a single restrictive control with layered controls for protecting intellectual property during remote work. Both can meet the minimum requirement, but their failure modes and employee impacts differ.

Which analysis BEST supports the final decision?

- A. Compare coverage of risk scenarios, failure tolerance, user impact, maintainability, and total cost.
- B. Choose whichever option is marketed most widely.
- C. Count the individual settings available in each option.
- D. Select the option preferred by the first project team consulted.

Question 32 (CISM2-089)

Scenario: A property management company has configured automated account suspension for departing contractors. Human resources, procurement, and building managers have not agreed who must trigger departures or resolve errors.

What must be completed before full deployment?

- A. Purchase additional licenses regardless of expected demand.
- B. Ask internal audit to operate the suspension process.
- C. Declare implementation complete because automation is configured.
- D. Define accountable triggers, exception handling, procedures, service levels, training, and acceptance criteria.

Question 33 (CISM2-090)

Scenario: A retailer repeatedly discovers security integration costs after signing acquisition agreements. Security participates only when acquired systems are connected to the corporate environment.

Which change would MOST improve program execution?

- A. Perform a larger technical review after every connection.
- B. Include risk-tiered security due diligence, requirements, and integration planning throughout the acquisition lifecycle.
- C. Assign internal audit responsibility for acquisition design.
- D. Require acquired companies to replace all systems before assessment.

Question 34 (CISM2-091)

Scenario: A consulting company introduced a client-data approval workflow. Usage is low because reviewers are unclear about their authority, notifications arrive after deadlines, and urgent requests have no defined path.

Which initial action would BEST improve adoption?

- A. Increase disciplinary action without investigating the workflow.
- B. Analyze adoption barriers and correct roles, workflow, exceptions, and reinforcement.
- C. Report implementation as complete because the system is available.
- D. Remove all approvals so users no longer bypass the process.

Question 35 (CISM2-092)

Scenario: A hospital will change access rules for thousands of clinical users. Functional testing passed, but the pilot excluded night-shift workflows, the service desk has no scripts, and rollback has not been tested.

What is the BEST decision?

- A. Deploy immediately because functional testing passed.
- B. Cancel the control because complete certainty is impossible.
- C. Delay rollout until workflows, support, risk, and rollback criteria are ready.
- D. Transfer accountability for clinical disruption to the software supplier.

Question 36 (CISM2-093)

Scenario: A distributor requires managers to review high-risk access quarterly. Review records show approvals, but the program has never checked whether terminated users were included or whether reviewers investigated unusual privileges.

How should the next test be designed?

- A. Confirm only that the review policy has executive approval.
- B. Count the total number of emails generated by the review system.
- C. Test population completeness, reviewer authority, timeliness, evidence of meaningful review, and exception handling.
- D. Ask the control operator whether the process usually works.

Question 37 (CISM2-094)

Scenario: Testing identifies twenty control deficiencies. Two affect a shared identity service used by all critical applications; the remaining findings are isolated documentation errors in low-risk processes.

What should drive remediation priority?

- A. Risk exposure, systemic reach, dependencies, root cause, and feasible corrective action
- B. The preference of the team with the largest budget
- C. An equal deadline for every finding regardless of impact
- D. The order in which findings were entered into the tracking system

Question 38 (CISM2-095)

Which situation creates the GREATEST concern about assurance objectivity?

- A. The control owner reviews operating metrics each month.
- B. The same manager designs, operates, tests, and approves the effectiveness conclusion for the control.
- C. An independent reviewer obtains additional evidence from the operator.
- D. Internal audit considers management's testing when planning its own work.

Question 39 (CISM2-096)

Scenario: A cloud access control is reported as effective because a configuration screenshot from launch day matches the standard. The service has changed repeatedly during the following six months.

What should the information security manager conclude?

- A. The screenshot proves continued operation for the entire period.
- B. Evidence is insufficient without design, change, operating, and exception coverage.
- C. Only the control owner may decide whether evidence is sufficient.
- D. The control needs no further evaluation because it is automated.

Question 40 (CISM2-097)

Which result BEST demonstrates that a security awareness program is effective?

- A. Relevant employee behavior improves and the targeted human-risk exposure declines.
- B. The annual presentation contains more technical detail than last year.
- C. Every employee receives the same message regardless of role.
- D. The security team sends reminders more frequently.

Question 41 (CISM2-098)

Scenario: Finance employees frequently send payment files to new external recipients. Annual training explains data handling, but errors occur when staff are under deadline pressure in the payment workflow.

Which improvement is MOST appropriate?

- A. Measure success only through attendance records.
- B. Repeat the same annual presentation twice a year for all employees.
- C. Add role-specific instruction and just-in-time prompts within the payment workflow, supported by targeted reinforcement.
- D. Make the security team approve every routine payment file.

Question 42 (CISM2-099)

Scenario: Employees increasingly report suspicious messages, but simulations show one sales region still enters credentials into realistic fraudulent sites at twice the enterprise rate.

Which action should follow the segmented result?

- A. Declare the program successful based solely on reporting volume.
- B. Stop simulations because they reveal inconsistent results.
- C. Send identical additional training to every region without analysis.
- D. Investigate workflow drivers, provide targeted training, and measure resulting behavior.

Question 43 (CISM2-100)

Scenario: A recruitment agency will use an external service to process applicant identity records. The provider offers a recent assurance report, but the proposed contract lacks incident notification and data-return terms.

What should the information security manager recommend?

- A. Accept the assurance report as a replacement for all contractual requirements.
- B. Assess report gaps and establish risk-based monitoring, incident, and exit terms.
- C. Transfer ownership of applicant records to the provider.
- D. Approve the service because recruitment needs it quickly.

Question 44 (CISM2-101)

Scenario: Three critical service providers rely on the same infrastructure subcontractor. Each direct provider passed onboarding separately, but the combined dependency has never been evaluated.

Which action should the manager take FIRST regarding this dependency?

- A. Assume the dependency is acceptable because each provider passed due diligence.
- B. Wait for a service interruption before updating the provider-risk process.
- C. Require the security team to operate the subcontractor's controls.
- D. Assess aggregate business impact, resilience, contractual visibility, and monitoring needs for the shared dependency.

Question 45 (CISM2-102)

Scenario: A media company is moving its digital archive to a new provider. The old provider can export files but not the access metadata needed to preserve restrictions, and the deletion method has not been agreed.

Which plan is MOST appropriate?

- A. Move the files immediately and rebuild access rights after users report problems.
- B. Keep both providers permanently to avoid transition decisions.
- C. Test content and metadata migration, continuity, access revocation, deletion, and acceptance.
- D. Rely on the old provider's standard termination email as proof of secure deletion.

Question 46 (CISM2-103)

Scenario: Executives receive separate security reports from eight departments. Definitions differ, totals conflict, and no report connects results to risk appetite or program objectives.

What should the information security manager implement?

- A. A longer technical appendix from each department
- B. Consistent outcome trends, risk thresholds, owners, and required decisions.
- C. A rule allowing every department to define effectiveness independently
- D. A dashboard that reports only positive results

Question 47 (CISM2-104)

Scenario: A product leader disputes a security finding and refuses remediation. Testing evidence is strong, potential impact exceeds an approved threshold, and the security manager lacks authority to accept the exposure.

How should the information security manager handle the issue NEXT?

- A. Publish the dispute broadly without following governance.
- B. Close the finding because the product leader disagrees.
- C. Accept the risk on behalf of the product leader.
- D. Escalate evidence, impact, ownership, alternatives, and the decision through governance.

Question 48 (CISM2-105)

Scenario: A public university's security roadmap depends on changes by academic departments. Department heads support the goals but say planned dates ignore teaching cycles and locally funded system replacements.

Which engagement approach should the manager use?

- A. Align outcomes, dependencies, timing, responsibilities, and risk tradeoffs with stakeholders.
- B. Remove all department-dependent initiatives from the program.
- C. Enforce the dates without considering academic dependencies.
- D. Let each department define unrelated security objectives.

Question 49 (CISM2-106)

Scenario: An insurance company replaces telephone claims with mobile self-service. Existing controls assume that employees verify claimants and review uploaded documents manually.

What should be assessed FIRST to maintain program effectiveness?

- A. Apply the employee procedure unchanged to mobile customers.
- B. Assess changed workflows, risks, obligations, and dependencies, then update the program.
- C. Wait for fraud trends before considering any control changes.
- D. Treat the mobile service as outside the security program.

Question 50 (CISM2-107)

Scenario: A delivery company wants to pilot autonomous inspection devices at distribution centers. The devices will collect video, connect to operational networks, and depend on a new external service.

What is the MOST appropriate program approach?

- A. Assess use cases, set provider guardrails, run a bounded pilot, and update requirements.
- B. Permit unrestricted deployment because the technology may improve efficiency.
- C. Ban all future use because existing standards do not name the technology.
- D. Allow each distribution center to create independent risk and architecture rules.

Answer Key

Domain III - Information Security Program

1 D	2 C	3 D	4 D	5 C
6 B	7 C	8 C	9 B	10 D
11 A	12 D	13 D	14 C	15 A
16 B	17 A	18 C	19 A	20 B
21 D	22 A	23 C	24 B	25 A
26 B	27 A	28 A	29 C	30 D
31 A	32 D	33 B	34 B	35 C
36 C	37 A	38 B	39 B	40 A
41 C	42 D	43 B	44 D	45 C
46 B	47 D	48 A	49 B	50 A

Detailed Explanations

Question 1 (CISM2-058)

Correct answer: D - The merged business objectives, critical services, obligations, and risk priorities

The program should derive its objectives from the merged enterprise's services, obligations, strategy, and risks. Technology inventories and preferred tools are inputs, while limiting work to controls requiring no change may leave important business risks untreated.

Question 2 (CISM2-059)

Correct answer: C - An executive-sponsored program charter defining authority, scope, objectives, and accountability

A sponsored charter resolves the missing authority and accountability needed to establish a program. Detailed configurations, inspections, and product choices may support later work but cannot substitute for an approved mandate.

Question 3 (CISM2-060)

Correct answer: D - Reassess risk, dependencies, capacity, and launch needs, then propose a revised roadmap.

The accelerated business milestone changes both exposure and required capability timing, so roadmap priorities and dependencies must be reassessed. Freezing the plan or adding unfunded work ignores constraints, and an operations team does not own the business launch decision.

Question 4 (CISM2-061)

Correct answer: D - Map information flows, services, obligations, and risks, then assign responsibilities at every organizational boundary.

Scope and accountability should follow the venture's information, services, obligations, and risk across shared boundaries. Ownership complexity is not a reason to exclude exposure, providers cannot accept all business risk, and using the weakest requirements lacks a risk basis.

Question 5 (CISM2-062)

Correct answer: C - Required outcomes, workload, service levels, competencies, dependencies, and sourcing options

Resource estimates should reflect the capability's expected outcomes, demand, service expectations, skills, dependencies, and delivery model. Reporting lines, unrelated headcount requests, and market activity do not establish the capacity needed to operate the capability.

Question 6 (CISM2-063)

Correct answer: B - Define provider deliverables and quality measures while retaining internal prioritization, ownership, and oversight.

The provider can deliver specialist work, but the organization should retain context-based prioritization, risk ownership, and service accountability. Outsourcing does not transfer risk acceptance, business change authority, or the need to monitor performance.

Question 7 (CISM2-064)

Correct answer: C - One linking expected risk reduction and operational benefits to lifecycle cost, dependencies, and measurable outcomes

A decision-quality business case connects the capability to risk reduction, operational value, full cost, implementation needs, and measurable results. Feature volume and personal preference lack business context, while a promise to eliminate all risk is not credible.

Question 8 (CISM2-065)

Correct answer: C - Assess capacity risk and establish backup skills, knowledge transfer, and sourcing.

The single-person dependency should be addressed through capacity analysis, cross-training, knowledge transfer, and sourcing. Withholding knowledge, using unprepared reviewers, or waiting for departure would leave the continuity and capacity risk untreated.

Question 9 (CISM2-066)

Correct answer: B - Information custodian

An information custodian implements handling, storage, and backup requirements on behalf of the accountable owner. Risk owners make risk decisions, policy approvers authorize direction, and auditors independently evaluate rather than operate the controls.

Question 10 (CISM2-067)

Correct answer: D - It links assets to business use, accountable owners, classification, location, and lifecycle state.

An inventory supports decisions when it connects information to business context, ownership, sensitivity, location, and lifecycle. Purchase source does not define information risk, uniform protection ignores differing needs, and audit-only updates allow the inventory to become stale.

Question 11 (CISM2-068)

Correct answer: A - Define and embed approved sharing, access, retention, and disposal requirements for the restricted classification.

Usable handling requirements translate the classification into consistent behavior across the document lifecycle. Relabeling masks risk, central approval of every access request is unlikely to scale, and counting labels does not show proper protection.

Question 12 (CISM2-069)

Correct answer: D - Discover the copies, assign accountable ownership, and apply classification, retention, and defensible disposition rules.

The organization first needs visibility and accountable decisions based on classification and retention requirements. Permanent storage preserves unnecessary exposure, analysts may lack ownership authority, and indiscriminate deletion could violate business or legal needs.

Question 13 (CISM2-070)

Correct answer: D - Confirm that the framework fits organizational objectives, risks, obligations, and operating context.

Framework selection should be based on fit with the organization's business, risk, regulatory, and operational context. A framework informs the program but does not remove risk decisions, require every practice, or automatically replace governance.

Question 14 (CISM2-071)

Correct answer: C - It directs effort toward relevant outcomes while preserving traceability to applicable requirements.

Risk-based tailoring prioritizes relevant outcomes while preserving traceability to applicable requirements. It does not permit convenience-based omission, guarantee elimination of residual risk, or remove the need for management oversight.

Question 15 (CISM2-072)

Correct answer: A - Map requirements to a shared control and evidence model with traceability.

A unified control and evidence model reduces duplication while preserving traceability to distinct obligations. Discarding requirements creates gaps, separation wastes effort, and description length is not a valid selection criterion.

Question 16 (CISM2-073)

Correct answer: B - Procedure

A procedure gives the operational steps for carrying out a task. Policy states direction, guidelines provide recommendations, and a charter establishes the program's mandate and scope.

Question 17 (CISM2-074)

Correct answer: A - When recommended approaches can help users meet requirements in varying circumstances

Guidelines provide recommended, adaptable ways to support compliance with governing requirements. Charters establish authority, risk acceptance requires accountable approval, and mandatory technical values belong in standards.

Question 18 (CISM2-075)

Correct answer: C - Assess the risk, set compensating controls and review conditions, then obtain time-bound approval.

A governed exception is justified, approved by the proper authority, supported by interim safeguards, monitored, and time-bound. Permanent exclusion and indefinite duration evade the standard, while the operator may not have risk-acceptance authority.

Question 19 (CISM2-076)

Correct answer: A - Have owners determine requirements, then approve and communicate one consistent rule.

The conflict requires an authoritative decision grounded in applicable requirements and communicated through aligned documents. Local choice produces inconsistency, longer retention can increase risk or violate requirements, and waiting leaves operations without valid direction.

Question 20 (CISM2-077)

Correct answer: B - Security architecture principles and shared capability requirements aligned with the enterprise service model

Architecture principles and capability requirements create consistent direction tied to the shared business model while allowing suitable implementations. Product lists and configuration details do not alone ensure alignment, and indefinite waivers preserve the incompatibility.

Question 21 (CISM2-078)

Correct answer: D - Embed security architecture requirements and representation into enterprise architecture decision points.

Integrating security into enterprise architecture governance introduces requirements when material platform decisions are made. Security should not replace enterprise architecture, audit should remain independent, and post-contract review repeats the late-engagement problem.

Question 22 (CISM2-079)

Correct answer: A - Traceability linking business objectives and risk scenarios to requirements, capabilities, and roadmap initiatives

Traceability explains how proposed capabilities and investments support business goals and address identified risks. Configuration detail, broad assertions, and staff qualifications do not show why the architectural choices are necessary.

Question 23 (CISM2-080)

Correct answer: C - Assess deviation risk, set interim safeguards, obtain approval, and track convergence.

A governed transition can accommodate a legitimate dependency while managing risk and preserving a path to the target architecture. Absolute rejection may be impractical, exclusion abandons oversight, and a vendor does not own the enterprise's residual risk.

Question 24 (CISM2-081)

Correct answer: B - Compare risk reduction, resilience, dependencies, transition controls, and exit criteria.

The roadmap decision should balance target-state benefits with transition risk, resilience, dependencies, business impact, and clear completion criteria. Cost or speed alone is insufficient, and uncoordinated migrations can undermine data integrity and program outcomes.

Question 25 (CISM2-082)

Correct answer: A - Active exceptions with authorized owners, safeguards, and timely review or closure.

Current ownership, safeguards, and timely review indicate whether exceptions are being governed as intended. Form access, implementation effort, and field counts measure inputs or activity rather than the quality of risk oversight.

Question 26 (CISM2-083)

Correct answer: B - Trends by risk tier, process stage, owner, backlog age, and cause.

Segmented process and risk data shows where delays occur, which exposure matters, and who can act. Dashboard appearance, unrelated policy counts, and questionnaire length do not reliably identify the cause or decision required.

Question 27 (CISM2-084)

Correct answer: A - Set maturity targets based on risk, business dependence, outcomes, and investment value.

Maturity targets should reflect the importance and value of each capability rather than a uniform score. Low maturity or peer averages do not alone justify investment, while thoughtful maturity assessment can still support prioritization and improvement.

Question 28 (CISM2-085)

Correct answer: A - To assess whether the design addresses its intended risk and requirement.

A clear objective enables design alternatives to be evaluated against the required risk-reducing result. It does not guarantee performance, remove ownership, or prescribe technology based on age rather than suitability.

Question 29 (CISM2-086)

Correct answer: C - Assess threats and requirements, then design proportionate controls within operating constraints.

A contextual design can meet the control objective through suitable alternative or layered safeguards without disregarding operational constraints. Forced installation creates business risk, exclusion abandons governance, and inability to use one control does not justify automatic acceptance.

Question 30 (CISM2-087)

Correct answer: D - The control lacks context to distinguish approved use and assign decisions.

Incomplete service context and ownership are design dependencies that can produce inappropriate blocking and unresolved exceptions. Interface features, price, and preventive operation do not address the core ability to make accountable, risk-based distinctions.

Question 31 (CISM2-088)

Correct answer: A - Compare coverage of risk scenarios, failure tolerance, user impact, maintainability, and total cost.

The decision should compare how well each strategy addresses relevant scenarios while remaining resilient, usable, maintainable, and economical. Marketing, setting counts, and one team's preference are not sufficient evidence of enterprise suitability.

Question 32 (CISM2-089)

Correct answer: D - Define accountable triggers, exception handling, procedures, service levels, training, and acceptance criteria.

The control needs agreed ownership, operating processes, support, and acceptance evidence before it can function reliably. More licenses do not resolve governance, audit should not operate the control, and configuration alone is not complete implementation.

Question 33 (CISM2-090)

Correct answer: B - Include risk-tiered security due diligence, requirements, and integration planning throughout the acquisition lifecycle.

Lifecycle participation allows security risks, costs, dependencies, and integration requirements to inform the transaction and transition. Post-connection review is late, universal replacement is not risk-based, and audit should provide assurance rather than design the acquisition controls.

Question 34 (CISM2-091)

Correct answer: B - Analyze adoption barriers and correct roles, workflow, exceptions, and reinforcement.

The control's operating model must address unclear authority, timing, and urgent cases so intended behavior is practical and governed. Punishment and availability reporting do not fix the barriers, while removing approval abandons the control objective.

Question 35 (CISM2-092)

Correct answer: C - Delay rollout until workflows, support, risk, and rollback criteria are ready.

A high-impact rollout needs evidence from representative use, operational support, and a viable recovery path. Limited functional success is insufficient, permanent cancellation is disproportionate, and supplier involvement does not transfer organizational accountability.

Question 36 (CISM2-093)

Correct answer: C - Test population completeness, reviewer authority, timeliness, evidence of meaningful review, and exception handling.

The test should determine whether the review covers the intended population and operates with appropriate judgment, timing, ownership, and follow-up. Policy approval, email counts, and operator statements do not provide sufficient evidence of sustained effectiveness.

Question 37 (CISM2-094)

Correct answer: A - Risk exposure, systemic reach, dependencies, root cause, and feasible corrective action

Risk and systemic impact should concentrate attention on weaknesses that can affect many critical services, while considering dependencies and sustainable correction. Submission order, budget influence, and uniform deadlines do not reflect the significance of the deficiencies.

Question 38 (CISM2-095)

Correct answer: B - The same manager designs, operates, tests, and approves the effectiveness conclusion for the control.

Combining design, operation, testing, and final approval under one manager creates a strong self-review threat. Owner monitoring is expected, reviewers may obtain operator evidence, and audit can use management testing while maintaining independent judgment.

Question 39 (CISM2-096)

Correct answer: B - Evidence is insufficient without design, change, operating, and exception coverage.

A launch-day screenshot is point-in-time evidence and does not address later changes or sustained operation. Automation does not eliminate assurance needs, and evidence sufficiency should be assessed objectively rather than solely by the control owner.

Question 40 (CISM2-097)

Correct answer: A - Relevant employee behavior improves and the targeted human-risk exposure declines.

Effectiveness is demonstrated by improved decisions or behavior and reduced targeted risk. Content volume, uniformity, and message frequency are activities that do not establish whether employees act more securely.

Question 41 (CISM2-098)

Correct answer: C - Add role-specific instruction and just-in-time prompts within the payment workflow, supported by targeted reinforcement.

Role-specific learning and decision-time reinforcement address the actual context in which errors occur. Repeating generic content remains poorly targeted, attendance is not behavioral evidence, and central approval of every file is unlikely to be scalable or properly owned.

Question 42 (CISM2-099)

Correct answer: D - Investigate workflow drivers, provide targeted training, and measure resulting behavior.

The segmented result identifies a specific residual behavior that should be investigated and addressed with targeted intervention and follow-up measurement. Enterprise reporting volume does not negate the gap, stopping measurement hides it, and uniform training may miss its cause.

Question 43 (CISM2-100)

Correct answer: B - Assess report gaps and establish risk-based monitoring, incident, and exit terms.

External assurance is useful only when assessed for scope and relevance and combined with appropriate lifecycle obligations and oversight. It does not replace contract terms, transfer information ownership, or justify bypassing risk governance for schedule reasons.

Question 44 (CISM2-101)

Correct answer: D - Assess aggregate business impact, resilience, contractual visibility, and monitoring needs for the shared dependency.

Separate assessments can miss enterprise concentration risk, so the shared dependency and its resilience implications require aggregate analysis. Passing individual reviews is not conclusive, the organization does not operate the subcontractor's controls, and waiting for failure is reactive.

Question 45 (CISM2-102)

Correct answer: C - Test content and metadata migration, continuity, access revocation, deletion, and acceptance.

A complete and tested transition must preserve both information and its protection context while addressing continuity, access termination, and verifiable deletion. File-only migration can expose content, indefinite duplication increases risk, and a generic email is weak evidence.

Question 46 (CISM2-103)

Correct answer: B - Consistent outcome trends, risk thresholds, owners, and required decisions.

Consistent definitions and decision-oriented reporting create a reliable enterprise view tied to objectives and risk thresholds. More disconnected detail worsens the problem, independent definitions prevent comparison, and positive-only reporting undermines oversight.

Question 47 (CISM2-104)

Correct answer: D - Escalate evidence, impact, ownership, alternatives, and the decision through governance.

A material issue outside the manager's authority belongs with the designated decision body, supported by clear evidence and options. Disagreement alone does not invalidate the finding, security should not assume the owner's authority, and uncontrolled publication bypasses governance.

Question 48 (CISM2-105)

Correct answer: A - Align outcomes, dependencies, timing, responsibilities, and risk tradeoffs with stakeholders.

Structured joint planning preserves enterprise outcomes while incorporating real delivery dependencies and assigning shared accountability. Unilateral dates may fail operationally, removal leaves risks untreated, and unrelated local objectives fragment the program.

Question 49 (CISM2-106)

Correct answer: B - Assess changed workflows, risks, obligations, and dependencies, then update the program.

The new channel changes actors, processes, evidence, and exposure, requiring a structured reassessment and program update. Reusing an employee procedure may not fit, waiting is reactive, and a business service cannot be excluded merely because it is new.

Question 50 (CISM2-107)

Correct answer: A - Assess use cases, set provider guardrails, run a bounded pilot, and update requirements.

A governed pilot enables business learning while controlling data, network, supplier, and operational risks and feeding evidence into program improvement. Unrestricted deployment lacks safeguards, a permanent ban prevents proportionate evaluation, and local rules would fragment governance and architecture.